



AEGENT SECURITY REVIEW

POINT-IN-TIME FIRST-PARTY ASSESSMENT

Smart-Contract Security Assessment

AEGENT Market, Redemption, Vault and Staking Contracts

REMEDiation REQUIRED BEFORE MAINNET

DOCUMENT CONTROL	VALUE
AEGENT internal document ID	AEG-SAR-2026-0730-01
Version / classification	1.0 / PUBLIC
Issue date	30 July 2026
Evidence snapshot	20260730T020710Z
Scope root SHA-256	5c51c8e5df9126e3b0a5ce15e98869f6130e43bb13e4caebf30853286763f0c

AUTHORED AND ISSUED BY

AEGENT Security Review Team

Document control

FIELD	CONTROLLED VALUE
AEGENT internal document ID	AEG-SAR-2026-0730-01
Report title	Smart-Contract Security Assessment — AEGENT Market, Redemption, Vault and Staking Contracts
Version	1.0
Status	Final first-party assessment
Classification	PUBLIC
Author / issuer	AEGENT Security Review Team
Issue date	30 July 2026
Assessment window	29–30 July 2026; evidence execution 30 July 2026
Evidence run	20260730T020710Z
Scope root SHA-256	5c51c8e5df9126e3b0a5ce15e98869f6130e43bb13e4caebf30853286763f0c
Evidence manifest SHA-256	760c48a488c7c0ab228773e18631e8463c82d879aac2c32ba03ed96c918b9b40
Repository context	cae20adbf0497c46906e36cb98bcd3d19232c98b (context only; snapshot is uncommitted)

Assessment statement

This report is a formal AEGENT-authored, point-in-time first-party security assessment of the exact frozen source snapshot identified above. It is suitable for public technical disclosure, internal release gating and submission to an independent security provider. It is not a warranty, certificate or independent third-party audit.

Any change to a scoped source file, interface, deployment script, test or configuration invalidates the corresponding evidence and requires a new snapshot and retest. The contextual Git commit is recorded only to locate the surrounding repository; it does not contain the uncommitted snapshot.

Revision history

VERSION	DATE	AUTHOR	CHANGE
1.0	30 July 2026	AEGENT Security Review Team	Formal consolidated report rebuilt against updated source snapshot.

Table of contents

1. Executive summary	4
1.1 Assessment facts at a glance	4
1.2 Finding disposition	4
2. Engagement and scope	6
2.1 Objectives	6
2.2 In-scope components	6
2.3 Scope identity	6
2.4 Explicit exclusions	6
3. Architecture and trust boundaries	8
3.1 Principal assets	8
3.2 Actors and assumptions	8
3.3 Staking economic semantics	9
4. Methodology	10
4.1 Review domains	10
4.2 Automated tools	10
4.3 Severity model	10
4.4 Status model	11
5. Assessment results	12
5.1 Positive controls verified	12
5.2 Release-blocking items	12
6. Detailed findings	13
6.1 MED-01 — Manual-review threshold could be bypassed by splitting redemptions	14
6.2 MED-02 — Purchases could create redemption liabilities without enforced reserve coverage ..	15
6.3 MED-03 — Oracle validation previously relied primarily on freshness	16
6.4 MED-04 — Staking oracle controls are materially weaker than purchase controls	17
6.5 LOW-01 — UTC day buckets permit a short-window boundary burst	18
6.6 INFO-01 — Privileged operations are not constrained by protocol-level multisig or timelock	19
6.7 INFO-02 — Immutable beneficiaries and narrow recovery paths create liveness risk	20

6.8 INFO-03 — Settlement events omit configuration evidence needed for independent reconstruction	21
6.9 INFO-04 — Staking proceeds depend indefinitely on a user-triggered claim	22
7. Automated verification evidence	23
7.1 Compilation and dynamic tests	23
7.2 Coverage	23
7.3 Slither static analysis	24
7.4 Dependency audit	24
8. Operational and deployment readiness	25
8.1 Deployment script boundary	25
8.2 Oracle-breaker keeper	25
8.3 Mandatory mainnet gates	25
9. Residual risk and limitations	26
9.1 Responsible disclosure	26
10. Conclusion	27
Appendix A — Scope file hashes	28
Appendix B — Reproducible command profile	29
Appendix C — Evidence index	29
Appendix D — Terminology	29

The table of contents and page references are updated during the controlled PDF export.

1. Executive summary

REMEDIATION REQUIRED BEFORE MAINNET

During the procedures described and within the frozen scope, no Critical or High finding was identified. One open Medium issue remains in Staking oracle validation, together with one open Low and four open Informational findings. Mainnet enablement should remain blocked until MED-04 is remediated or explicitly risk-accepted and the deployment gates in Section 8 are independently verified.

CRITICAL	HIGH	MEDIUM	LOW	INFO
0	0	1	1	4
OPEN	OPEN	OPEN	OPEN	OPEN

The updated snapshot materially improves the original design. Cumulative wallet thresholds close the redemption splitting path; reserve coverage is enforced before every purchase; and Swap now applies feed-specific age, bounds, deviation controls and a permissionless persistent breaker.

The remaining security priority is consistency: Staking still applies a freshness-only oracle model that is weaker than Swap. Governance, immutable beneficiary design, event evidence and claim-dependent proceeds release also remain explicit operational risks.

1.1 Assessment facts at a glance

METRIC	VERIFIED RESULT
Production Solidity scope	5 core contracts + 6 interfaces; 3,287 LOC
Frozen package	35 source, test, script and configuration files
Compilation	34 Solidity files; 0 compiler errors
Dynamic tests	74 passing / 1 intentional pending on chain 56; wrong-chain guard 1/1 passing on chain 97
Coverage — all instrumented files	96.18% statements; 59.91% branches; 97.66% functions; 87.01% lines
Static analysis	Slither 0.11.5; 71 raw detector records manually triaged
Production dependency audit	0 known npm advisories in production dependencies
Deployment evidence	Not provided; no addresses, bytecode or funded receipts assessed

1.2 Finding disposition

SEVERITY	OPEN	MITIGATED	RESOLVED	TOTAL
Critical	0	0	0	0

SEVERITY	OPEN	MITIGATED	RESOLVED	TOTAL
High	0	0	0	0
Medium	1	1	2	4
Low	1	0	0	1
Informational	4	0	0	4

2. Engagement and scope

2.1 Objectives

- Determine whether the updated contracts preserve authorization, custody, accounting and state-transition invariants.
- Retest previously reported Medium controls and identify new issues introduced by Staking and oracle-breaker operations.
- Measure repeatable test, coverage, static-analysis and dependency evidence against a cryptographically frozen snapshot.
- Define explicit release gates without asserting deployment, third-party certification or live-chain behavior not evidenced.

2.2 In-scope components

COMPONENT	SECURITY PURPOSE
AagentMarketRegistry	Sale schedule, modes, committed endpoints and configuration versions
AagentSwapV2	BNB/USDT/USDC purchases, oracle controls, inventory and proceeds forwarding
AagentSaleProceedsVault	Locks sale proceeds until sale end and releases to immutable beneficiary
AagentRedemptionV2	Cost-basis refunds, purchased-AGNT claims and post-launch redemption
AagentStakingV1	Term-locked deposits with maturity AGNT entitlement and beneficiary proceeds release
Interfaces and scripts	Binding contracts, BSC deployment safety and oracle-breaker keeper behavior

2.3 Scope identity

The authoritative evidence run is 20260730T020710Z. The scope-root SHA-256 is 5c51c8e5df9126e3b0a5ce15e98869f6130e43bb13e4caaebf30853286763f0c. It is computed over the ordered production Solidity path/hash pairs. Full per-file hashes appear in Appendix A.

SNAPSHOT VALIDITY

The build pipeline refuses to generate this report when any of the 33 live audit inputs differs from the frozen manifest. Two earlier intermediate runs were explicitly invalidated after source or test changes and are not cited anywhere in this report.

2.4 Explicit exclusions

- No deployed contract address, runtime bytecode, constructor transaction or explorer verification.

- No production multisig, owner, beneficiary, oracle, treasury or token address validation.
- No funded mainnet purchase, redemption, claim, staking or release receipt.
- No front-end, API, custody service, database or economic market-liquidity audit except where a contract interface depends on it.
- No formal verification, symbolic execution, long-duration fuzzing, key-compromise exercise or third-party independent review.

3. Architecture and trust boundaries

AEGENT contract architecture and trust boundaries

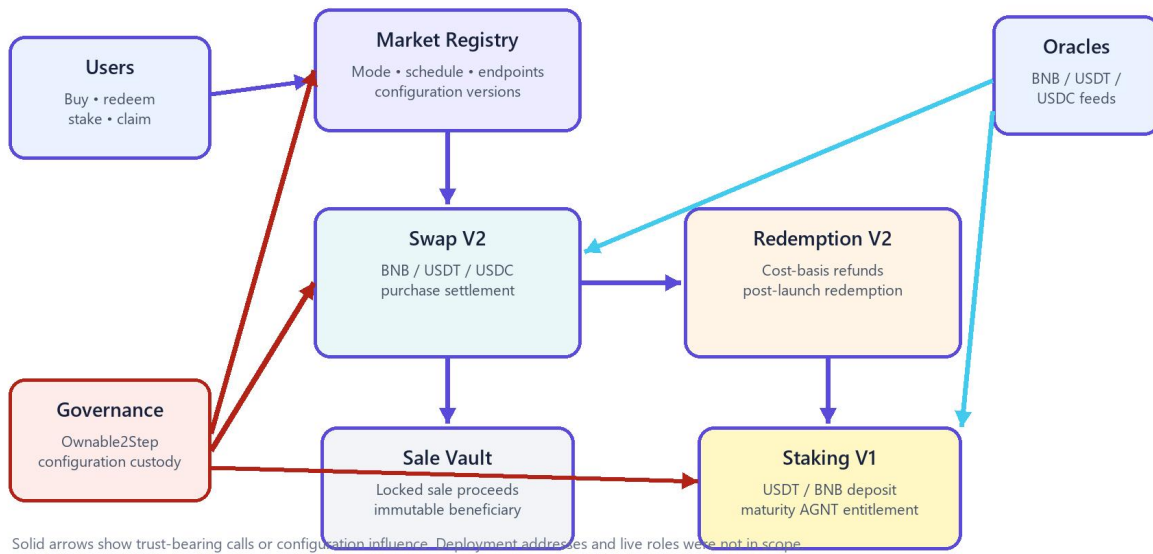


Figure 1 — Reviewed call and trust relationships. Live deployment identities were not in scope.

3.1 Principal assets

ASSET	SECURITY PROPERTY
AGNT inventory and entitlement	Cannot be oversold, over-reserved, withdrawn while owed or delivered twice
USDT / USDC / BNB sale proceeds	Correct valuation, atomic forwarding and locked release
Refund reserve	Covers outstanding cost-basis liability and rejects unsafe incremental purchases
Staking deposits	Single position accounting, maturity enforcement and one-time proceeds release
Configuration state	Versioned, role-bound, mode-safe and reconstructable
Oracle data	Fresh, bounded, deviation-checked and fail-closed when unhealthy

3.2 Actors and assumptions

ACTOR	TRUST / ADVERSARY MODEL
Buyer / redeemer / staker	Untrusted; may choose timing, split calls, replay data and target boundaries
Owner	Highly trusted; can configure modes, oracle policy, rates and withdrawals
Keeper	Operationally trusted for availability, not authorization; breaker call is permissionless

ACTOR	TRUST / ADVERSARY MODEL
Oracle feed	External dependency; may be stale, malformed or economically wrong while syntactically valid
Beneficiary	Trusted and immutable recipient; must remain able to receive BNB and tokens
Token contracts	Expected standard behavior; fee-on-transfer USDT deposits are rejected

3.3 Staking economic semantics

IMPORTANT PRODUCT FACT

AgentStakingV1 is a term-lock / deferred-entitlement contract. A user deposits USDT or BNB and, after maturity, claims principalAgnt plus rewardAgnt. The deposited asset is then released to the beneficiary; it is not returned to the user as staking principal.

4. Methodology

4.1 Review domains

REVIEW DOMAIN	CONTROL QUESTIONS
Authorization and governance	Ownership transfer, onlyOwner surface, endpoint commitment, breaker authority
Custody and liveness	AGNT reservation, reserve locks, beneficiary release, accidental-asset behavior
Accounting and economics	Phase rates, cost basis, partial refunds, daily limits, staking reward interpolation
Oracle safety	Round completeness, age, bounds, deviation, reference prices, breaker persistence
Execution integrity	Deadlines, nonces, minOut, checks-effects-interactions, reentrancy and replay
Time and lifecycle	Sale boundaries, limited windows, claim maturity, post-launch rate activation
Evidence and observability	Events, configuration versions, deployment artifacts and reproducibility

4.2 Automated tools

TOOL	VERSION / CONFIGURATION	PURPOSE
Solidity compiler	0.8.24; optimizer 500; EVM paris	Deterministic compilation
Hardhat	2.29.0; chainId 56 / wrong-chain 97	Unit and integration execution
solidity-coverage	0.8.17; chainId 56	Statement, branch, function and line coverage
Slither	0.11.5; crytic-compile 0.3.11	Static detector inventory with manual triage
npm audit	Registry-backed production dependency scan	Known advisory check
SHA-256 manifest	Ordered relative paths and file digests	Snapshot identity and build gate

4.3 Severity model

SEVERITY	PRACTICAL INTERPRETATION
Critical	Direct and broadly exploitable loss, permanent protocol compromise or system-wide insolvency
High	Material loss or control compromise under realistic preconditions
Medium	Meaningful security or economic impact requiring specific state, role or market conditions
Low	Limited impact, boundary weakness or defense-in-depth gap
Informational	Governance, observability, operational or maintainability risk

4.4 Status model

Resolved means the reviewed snapshot contains the remediation and fresh tests exercise it. Partially Resolved means material controls exist but a documented residual dependency remains. Open means the condition remains in scope. These are AEGENT first-party statuses and are not third-party closure decisions.

5. Assessment results

ID	SEVERITY	STATUS	TITLE
MED-01	Medium	Resolved	Manual-review threshold could be bypassed by splitting redemptions
MED-02	Medium	Resolved	Purchases could create redemption liabilities without enforced reserve coverage
MED-03	Medium	Partially Resolved	Oracle validation previously relied primarily on freshness
MED-04	Medium	Open	Staking oracle controls are materially weaker than purchase controls
LOW-01	Low	Open	UTC day buckets permit a short-window boundary burst
INFO-01	Informational	Open	Privileged operations are not constrained by protocol-level multisig or timelock
INFO-02	Informational	Open	Immutable beneficiaries and narrow recovery paths create liveness risk
INFO-03	Informational	Open	Settlement events omit configuration evidence needed for independent reconstruction
INFO-04	Informational	Open	Staking proceeds depend indefinitely on a user-triggered claim

5.1 Positive controls verified

- Fixed 90-day sale schedule and five-mode registry with versioned operational changes.
- Committed endpoint and registry-binding checks before enabling purchase or redemption.
- Wallet-bound nonces, deadlines, expected phase/mode/config versions and minOut validation.
- Cost-basis presale refunds, AGNT claim escrow and reserve/claim withdrawal locks.
- Per-feed purchase oracle age, bounds, deviation and permissionless breaker controls.
- Reentrancy guards and balance-delta checks on staking deposits and settlement transfers.
- Chain-56 constructor guard for Staking and irreversible-broadcast confirmation for deployment scripts.

5.2 Release-blocking items

RELEASE DECISION

MED-04 should be remediated or formally risk-accepted before enabling Staking deposits. All deployment addresses, immutable bindings, source verification, multisig/timelock ownership, token/oracle identities, reserve funding and minimum-value mainnet transactions remain separate required gates.

6. Detailed findings

Each finding below records the AEGENT first-party severity, current snapshot status, affected surface, supporting evidence, remediation guidance and retest statement.

6.1 MED-01 — Manual-review threshold could be bypassed by splitting redemptions

SEVERITY	Medium	STATUS	Resolved
AFFECTED	AegentRedemptionV2	LIKELIHOOD	Low after remediation
IMPACT	Control bypass and excessive wallet-level redemption throughput	EVIDENCE	AegentRedemptionV2.sol:734–757; AegentRedemptionV2.test.cjs cumulative-threshold tests
REPORT ID	MED-01	SNAPSHOT	20260730T020710Z

Description

The earlier implementation evaluated the manual-review threshold at request level. The reviewed snapshot now computes the wallet's next cumulative UTC-day redemption total before applying both the hard wallet limit and the manual-review threshold.

Impact and exploit conditions

Control bypass and excessive wallet-level redemption throughput.

The previous weakness required a wallet to submit multiple individually sub-threshold transactions. The cumulative accounting in this snapshot removes that path.

Recommendation

Retain cumulative accounting and monitoring. If the business policy is intended to mean any rolling 24-hour period, also address LOW-01.

Validation status

RESOLVED

Fresh chain-56 tests passed: “applies the manual-review threshold to the cumulative wallet total” and “retains the hard daily wallet limit when the review threshold equals it.”

6.2 MED-02 — Purchases could create redemption liabilities without enforced reserve coverage

SEVERITY	Medium	STATUS	Resolved
AFFECTED	AagentSwapV2; AagentRedemptionV2	LIKELIHOOD	Low after remediation
IMPACT	Insolvent presale refunds or inability to honor cost-basis liabilities	EVIDENCE	AagentRedemptionV2.sol:588–610; AagentSwapV2.sol:299–340, 630–687, 770–799
REPORT ID	MED-02	SNAPSHOT	20260730T020710Z

Description

The reviewed contracts now expose the projected reserve requirement for an incremental purchase and require every BNB, USDT and USDC execution path to fail closed when the redemption reserve cannot cover the resulting liability.

Impact and exploit conditions

Insolvent presale refunds or inability to honor cost-basis liabilities.

The previous condition required additional purchases to be accepted while refund reserves were insufficient or unreadable. The current quote and execution paths reject that state.

Recommendation

Preserve the fail-closed reserve check in every future purchase path and monitor both reserve assets and outstanding cost-basis liabilities.

Validation status

RESOLVED

Fresh tests passed for reserve coverage on BNB, USDT and USDC purchases, unreadable reserve state, locked liability and excess-only withdrawals.

6.3 MED-03 — Oracle validation previously relied primarily on freshness

SEVERITY	Medium	STATUS	Partially Resolved
AFFECTED	AgentSwapV2; AgentMarketRegistry; oracle-breaker keeper	LIKELIHOOD	Low to Medium
IMPACT	Incorrect purchase valuation if a valid-looking feed value is materially wrong	EVIDENCE	AgentSwapV2.sol:38–53, 346–463, 843–879, 970–1055; AgentMarketRegistry.sol:143–181
REPORT ID	MED-03	SNAPSHOT	20260730T020710Z

Description

The snapshot adds per-feed maximum age, absolute bounds, deviation limits, reference prices and a permissionless circuit breaker that persistently pauses purchase-capable modes. Registry logic rejects breaker calls after sale end and from uncommitted endpoints.

Impact and exploit conditions

Incorrect purchase valuation if a valid-looking feed value is materially wrong.

Residual exposure remains if the single upstream source is compromised within configured bounds, if the owner sets an unsafe reference while paused, or if operational monitoring, RPC access and gas are unavailable.

Recommendation

Control oracle-risk configuration through a multisig and timelock, monitor reference-price changes, document per-feed heartbeats, and consider a secondary source or TWAP for high-value execution.

Validation status

PARTIALLY RESOLVED

Fresh tests passed for per-feed ages, bounds, deviation checks, breaker classification, permissionless trip behavior, post-sale rejection and post-launch redemption continuity. Residual operational assumptions were not eliminated.

6.4 MED-04 — Staking oracle controls are materially weaker than purchase controls

SEVERITY	Medium	STATUS	Open
AFFECTED	AagentStakingV1	LIKELIHOOD	Medium
IMPACT	Inflated AGNT entitlement and reserve depletion from a fresh but anomalous BNB price	EVIDENCE	AagentStakingV1.sol:113, 133–190, 240–261, 493–517
REPORT ID	MED-04	SNAPSHOT	20260730T020710Z

Description

Staking uses one immutable maxOracleAge for both feeds and accepts any positive, non-future, round-complete value within that age. It has no per-feed heartbeat cap, absolute price bounds, deviation limit, reference price or circuit breaker. BNB valuation is not capped; a fresh extreme value can create an excessive AGNT entitlement. USDT valuation caps prices above one dollar but still relies on user minOut for low-price protection.

```
uint256 public immutable maxOracleAge;
...
if (block.timestamp - updatedAt > maxOracleAge) {
    revert StaleOraclePrice(address(feed), updatedAt);
}
return uint256(answer) * feedScale;
```

Impact and exploit conditions

Inflated AGNT entitlement and reserve depletion from a fresh but anomalous BNB price.

An oracle, upstream data path or feed configuration returns a fresh, positive but materially incorrect value. A user executes before operators can close deposits.

Recommendation

Reuse the Swap oracle-risk model: bounded per-feed maximum age, min/max price, reference/deviation validation, permissionless persistent breaker, and explicit tests at the first representable boundary breach. Enforce a safe upper bound on configured heartbeat.

Validation status

OPEN

No remediation for this issue exists in the reviewed snapshot. Existing tests cover stale, future, incomplete and non-positive rounds but do not provide the missing bounds/deviation controls.

6.5 LOW-01 — UTC day buckets permit a short-window boundary burst

SEVERITY	Low	STATUS	Open
AFFECTED	AagentRedemptionV2	LIKELIHOOD	Medium
IMPACT	A wallet can approach twice the nominal daily amount across UTC midnight	EVIDENCE	AagentRedemptionV2.sol:734–757
REPORT ID	LOW-01	SNAPSHOT	20260730T020710Z

Description

Daily global and wallet counters use `block.timestamp / 1 days`. A wallet can consume the full limit immediately before UTC midnight and the next full limit immediately after the bucket changes.

```
| quote.dayIndex = block.timestamp / 1 days;
```

Impact and exploit conditions

A wallet can approach twice the nominal daily amount across UTC midnight.

The user has available entitlement and reserve on both sides of a UTC-day boundary. This is a rate-limit design issue, not a timestamp manipulation by a block producer.

Recommendation

Use a rolling-window, token-bucket or decaying accumulator if the intended policy is a true 24-hour limit. Otherwise document the UTC-bucket behavior as an accepted business rule and monitor boundary utilization.

Validation status

OPEN

The snapshot retains the UTC bucket; no rolling-window retest is available.

6.6 INFO-01 — Privileged operations are not constrained by protocol-level multisig or timelock

SEVERITY	Informational	STATUS	Open
AFFECTED	Registry; Swap; Redemption; Staking	LIKELIHOOD	Operational
IMPACT	Single-key compromise or error can change modes, oracle policy or withdrawals	EVIDENCE	Registry setMode/configureLimitedWindow; Swap setOracleRiskConfig/withdrawUnsoldAgnt; Redemption rate and withdrawal functions; Staking deposit and surplus controls
REPORT ID	INFO-01	SNAPSHOT	20260730T020710Z

Description

The contracts use Ownable2Step, which protects ownership transfer but does not enforce multisig approval, delay high-impact changes or separate duties.

Impact and exploit conditions

Single-key compromise or error can change modes, oracle policy or withdrawals.

The deployed owner is an externally owned account, a weakly configured Safe, or an operational process with insufficient review.

Recommendation

Assign ownership to a verified multisig, apply a timelock to high-impact configuration, separate keeper and treasury duties, and publish an on-chain role matrix before enabling production modes.

Validation status

OPEN

Deployment addresses and live ownership were not provided; no on-chain retest was possible.

6.7 INFO-02 — Immutable beneficiaries and narrow recovery paths create liveness risk

SEVERITY	Informational	STATUS	Open
AFFECTED	AagentSaleProceedsVault; AagentStakingV1	LIKELIHOOD	Operational
IMPACT	Proceeds or accidental assets can remain locked if the recipient cannot receive them	EVIDENCE	AagentSaleProceedsVault.sol:30–92; AagentStakingV1.sol:108–199, 334–361
REPORT ID	INFO-02	SNAPSHOT	20260730T020710Z

Description

Vault and Staking proceeds are bound to immutable beneficiaries. Native release reverts if the recipient rejects BNB, while token recovery is limited to expected assets. A lost or unusable beneficiary cannot be rotated in the reviewed bytecode.

Impact and exploit conditions

Proceeds or accidental assets can remain locked if the recipient cannot receive them.

The beneficiary contract rejects native transfers, loses signing access, is misconfigured, or an unsupported asset is sent to the contract.

Recommendation

Use a tested Safe-compatible beneficiary, add delayed two-step beneficiary rotation or a narrowly scoped recovery path, and test native/token release against the exact production recipient.

Validation status

OPEN

No production beneficiary or funded release transaction was supplied.

6.8 INFO-03 — Settlement events omit configuration evidence needed for independent reconstruction

SEVERITY	Informational	STATUS	Open
AFFECTED	AagentSwapV2; AagentRedemptionV2	LIKELIHOOD	Operational
IMPACT	Reduced auditability and more difficult incident reconstruction	EVIDENCE	AagentSwapV2.sol:129–138, 1127–1136; AagentRedemptionV2.sol:122–133, 349–360
REPORT ID	INFO-03	SNAPSHOT	20260730T020710Z

Description

PurchaseSettled does not emit market mode or configVersion. RedemptionSettled does not emit configVersion, rateVersion or whether the presale cost-basis path was used. Off-chain systems must join historical state to reconstruct settlement context.

Impact and exploit conditions

Reduced auditability and more difficult incident reconstruction.

An investigator or reconciler must prove which configuration governed a historical settlement.

Recommendation

Add the governing mode/config/rate identifiers and settlement-basis flag to events. Version the event schema and update indexers before deployment.

Validation status

OPEN

The reviewed snapshot retains the current event schemas.

6.9 INFO-04 — Staking proceeds depend indefinitely on a user-triggered claim

SEVERITY	Informational	STATUS	Open
AFFECTED	AegentStakingV1	LIKELIHOOD	Operational
IMPACT	Deposited USDT or BNB can remain locked indefinitely when a user never claims	EVIDENCE	AegentStakingV1.sol:312–361
REPORT ID	INFO-04	SNAPSHOT	20260730T020710Z

Description

Only the position owner can call claim. The beneficiary can release the corresponding deposited asset only after claimed becomes true. There is no third-party claim-for path or post-maturity fallback.

Impact and exploit conditions

Deposited USDT or BNB can remain locked indefinitely when a user never claims.

A position matures but its owner loses access, abandons the wallet or never submits the claim.

Recommendation

Consider a permissionless claim-for function that always delivers AGNT to the recorded owner, or a carefully specified post-maturity fallback that does not reduce the user's entitlement. Document long-tail liabilities.

Validation status

OPEN

Existing tests verify the designed owner-only claim and release sequence; they do not remove the liveness dependency.

7. Automated verification evidence

7.1 Compilation and dynamic tests

SUITE	RESULT	EVIDENCE
Hardhat clean + compile	34 Solidity files; success	hardhat-check.txt
Chain-56 main suite	74 passing; 1 intentional pending	hardhat-check.txt
Chain-97 constructor guard	1 passing	hardhat-check.txt
Coverage-instrumented suite	74 passing; 1 intentional pending	solidity-coverage.txt

The pending test is the wrong-chain constructor guard while the main suite runs on chainId 56. The same guard is then executed and passes in the separate chainId 97 configuration.

7.2 Coverage

FILE	STMTS	BRANCH	FUNCS	LINES
AagentMarketRegistry.sol	93.22%	67.44%	100.00%	91.26%
AagentRedemptionV2.sol	94.58%	51.58%	92.59%	80.57%
AagentSaleProceedsVault.sol	100.00%	28.13%	100.00%	78.13%
AagentStakingV1.sol	97.94%	78.77%	100.00%	97.89%
AagentSwapV2.sol	96.89%	53.96%	97.14%	85.11%
All production contracts	96.02%	59.30%	97.09%	86.25%
All instrumented files	96.18%	59.91%	97.66%	87.01%

COVERAGE INTERPRETATION

Coverage measures exercised code, not exploit absence. Branch coverage remains the weakest metric, particularly for Redemption and Vault. Boundary, failure and invariant tests should continue to grow.

7.3 Slither static analysis

RAW IMPACT LABEL	COUNT
Medium	30
Low	34
Informational	7
Total	71

Slither completed successfully at the JSON level. Its process exit code is non-zero when detector records exist; the JSON success flag was true. Raw tool impact labels are not report severities. All 71 records have a record-level disposition in `slither-triage-register.json` (SHA-256 `e066c0fd6215640e3348b981af6af6524ec0b4ff5427b529e38e743d8ddc98e5`).

DETECTOR	RAW COUNT	MANUAL DISPOSITION
timestamp	31	Lifecycle comparisons reviewed; LOW-01 retained as a separate manual design finding
incorrect-equality	16	Intentional zero, enum, sentinel and exact-boundary validation
uninitialized-local	9	Try/catch and named-output defaults; no uninitialized storage use found
low-level-calls	4	Expected native transfers; balance/state ordering reviewed
unused-return	3	Unused tuple fields; required round fields are checked
locked-ether	2	Production Redemption receive reverts; second record is a test mock
other detectors	6	Record-level disposition and evidence location are listed in the triage register

7.4 Dependency audit

DEPENDENCY	VERSION	RESULT
@openzeppelin/contracts	5.1.0	0 production advisories reported by npm audit
ethers	6.17.0	Development/test dependency
hardhat	2.29.0	Development/test dependency
Total production dependency count	2	0 info / low / moderate / high / critical advisories

The npm result is a point-in-time registry advisory query, not a guarantee that dependencies are free of undisclosed vulnerabilities. The execution time, registry and lockfile hash are recorded in `npm-audit-command.json`.

8. Operational and deployment readiness

8.1 Deployment script boundary

The reviewed BSC deployment script predicts and deploys Registry, Swap and Redemption, with the Sale Vault created by Swap. It validates chain 56, schedule boundaries, endpoint bindings and reviewed oracle-age inputs. The current source derives the three initial oracle reference prices from the Swap deployment receipt, rejects missing, duplicate and unknown feed events, and checks those immutable deployment facts against live state. It does not deploy or verify Staking.

8.2 Oracle-breaker keeper

The keeper validates chainId 56, bytecode, Registry binding and feed code; it only monitors purchase-capable modes before sale end. Error logs redact configured RPC URLs, private keys and generic URLs. Availability still depends on an external process, RPC, gas and key custody. Because breaker trip is permissionless, keeper outage does not remove the manual on-chain path.

8.3 Mandatory mainnet gates

GATE	REQUIRED EVIDENCE	STATUS
G-01	Remediate or formally risk-accept MED-04 and add boundary tests	BLOCKING
G-02	Deploy all intended components, including Staking if enabled	BLOCKING
G-03	Verify source and constructor arguments on the selected explorer	BLOCKING
G-04	Verify immutable token, feed, beneficiary and Registry bindings	BLOCKING
G-05	Transfer ownership to tested multisig / timelock and document thresholds	BLOCKING
G-06	Fund AGNT inventory and refund reserves; reconcile liabilities	BLOCKING
G-07	Run minimum-value BNB/USDT/USDC purchase, refund, claim and staking tests	BLOCKING
G-08	Verify breaker keeper monitoring, alerts, gas funding and failover	REQUIRED
G-09	Archive bytecode, addresses, tx hashes, events and configuration evidence	REQUIRED

DEPLOYMENT STATUS

No deployment directory, production address list, verified bytecode, constructor transaction, funded receipt or live role evidence was supplied. This report must not be interpreted as a deployed-system certification.

9. Residual risk and limitations

- Security depends on exact deployment parameters, token/feed identities, role custody and reserve funding that were not assessed.
- Oracle controls reduce but do not eliminate dependence on upstream data, RPC availability, gas and operator policy.
- High test coverage does not prove economic correctness under all market, sequencing or governance conditions.
- No stateful invariant fuzzing, symbolic execution, formal proof or adversarial mainnet fork exercise was completed.
- The assessment is first-party and does not substitute for independent review before material funds are exposed.
- The report applies only to the scope root printed on every controlled copy; any code change requires retest.

9.1 Responsible disclosure

Security reports should identify the report document ID, evidence run and scope-root hash. Sensitive exploit details should be sent through AEGENT's controlled security contact channel rather than public issue trackers.

10. Conclusion

REMEDATION REQUIRED BEFORE MAINNET

The updated contracts demonstrate substantial remediation and a stronger fail-closed posture. The purchase and redemption controls are materially improved; automated checks completed and their outputs were manually triaged. Staking oracle validation remains the principal open Medium risk.

AEGENT should keep mainnet enablement gated until MED-04 and the deployment evidence checklist are closed. LOW-01 and the Informational items should be resolved or explicitly documented as accepted operating assumptions.

This conclusion is valid only for evidence run 20260730T020710Z and scope root 5c51c8e5df9126e3b0a5ce15e98869f6130e43bb13e4caaebf30853286763f0c. No statement is made about unreviewed code, deployed bytecode, live balances or third-party endorsement.

AEGENT SECURITY REVIEW TEAM

Issued 30 July 2026 • AEG-SAR-2026-0730-01 • v1.0

Appendix A — Scope file hashes

RELATIVE PATH	LOC	SHA-256
contracts/AagentMarketRegistry.sol	406	7bb6cf38a0b59e52564f8fa83be1a24ad33456286f712eb239ad681f83dbfb32
contracts/AagentRedemptionV2.sol	925	1353e6b2ef4382cd544bd321141e071d3b50e7a3704e31387847ce1ceebfcf13
contracts/AagentSaleProceedsVault.sol	109	983af93be4bb1fcbe2809c9fb01baea34a7bae0ddf12caf05933c5450842cc34
contracts/AagentStakingV1.sol	557	789b1839a17e021b5e9cca679b8332e53ea6615644ef422ec30349e4c3b0abde
contracts/AagentSwapV2.sol	1142	c93726e35beb4d5bbdbfe37353f03c8418dc9be1add5d333c9aaedb0620d2334
contracts/interfaces/IAagentMarketRegistry.sol	70	20f86c9d6927aec67a51bdf5bf7fa2ce8fbbeaa76ea577ca410c42f6f382b76
contracts/interfaces/IAagentPurchaseReceiptSource.sol	28	52abd846c87734040bfb375177186bff6d8b56f9b23ddbeeb8a7a4f4c3d5badb
contracts/interfaces/IAagentRedemptionEndpoint.sol	13	b78ac12e384e2c71bdf33eb44a899c417c30eb4a9376fb28351d85c50bcf369d
contracts/interfaces/IAagentRegistryBound.sol	8	bf53c7606cbc5853a74710c9fa31dfd256a31283eedaf7ede01e213b0f12bc84
contracts/interfaces/IAagentSaleProceedsVault.sol	12	eb1005d38941efc7dfd9e8c961eb5a4df10f9a43f630330495dd82b73854c974
contracts/interfaces/IAggregatorV3.sol	17	2dc0d69856b9cf3579d866c1da3bb9baff2fe505d9702001fcddc47e319a2b7e

Production Solidity total: 11 files / 3,287 LOC. Scope root: 5c51c8e5df9126e3b0a5ce15e98869f6130e43bb13e4caaebf30853286763f0c.

Appendix B — Reproducible command profile

Commands are normalized to project-relative paths; machine-specific isolated tool paths are intentionally omitted.

```
Set-Location <project>/合约
npm run check

hardhat --config ../docs/security/audits/tools/hardhat.coverage.config.cjs coverage

hardhat --config ../docs/security/audits/tools/hardhat.slither.config.cjs compile --force
slither . --hardhat-ignore-compile --exclude-dependencies --json slither-0.11.5.json

npm audit --omit=dev --json
```

Appendix C — Evidence index

EVIDENCE ARTIFACT	PURPOSE
snapshot-manifest.json	Frozen 35-file package, hashes, timestamps and scope root
hardhat-check.txt	Clean compile, chain-56 tests and chain-97 wrong-chain test
solidity-coverage.txt	Instrumented test result and coverage table
coverage.json / coverage-html	Machine-readable and rendered coverage evidence
slither-0.11.5.json	Raw Slither detector output
slither-summary.json	Raw detector counts by impact and check
slither-triage-register.json	Record-level detector disposition and report linkage
npm-audit-production.json	Production dependency advisory result
source-snapshot/	Frozen contracts, interfaces, tests, scripts and configuration

Appendix D — Terminology

TERM	DEFINITION
Scope root	SHA-256 over ordered production Solidity relative-path/hash pairs
First-party assessment	Security review authored by the project organization itself
Independent review	Assessment performed and issued by a separate security organization
Fail closed	Reject execution when a required dependency or fact cannot be verified
Cost basis	Actual USD value contributed for the purchased AGNT being refunded
Breaker	Permissionless on-chain action that persistently pauses purchase-capable modes
Residual risk	Risk remaining after a control is implemented

